



ARKA HEALTH, INC.

COMPLIANCE ROADMAP & CERTIFICATION TIMELINE

Program status, external-claims standard, and certification milestones — suitable for investor and customer diligence

ARKA-RDY-004 · Version 1.0 · Confidential — May be shared under NDA

Document No.	ARKA-RDY-004
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — May be shared under NDA
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. WHERE ARKA STANDS TODAY

ARKA Health, Inc. is a pre-commercial clinical-software company. As of June 2026: (a) the complete HIPAA privacy and security policy suite (ARKA-GOV/PRIV/SEC series) has been adopted and is in force; (b) the public demonstration environment processes **synthetic data only — no PHI** (ARKA-DEMO-001); (c) the initial enterprise risk analysis is complete (ARKA-RDY-001) with remediation underway; (d) a BAA template (ARKA-LGL-001) is ready for counsel-reviewed execution with the first design partners; and (e) SOC 2 and HITRUST e1 readiness programs are active (ARKA-RDY-002/003). HIPAA has no government certification; compliance is demonstrated through exactly this documentation, its implementation, and its evidence trail.

2. MILESTONE TIMELINE

Window	Milestone	Owner
Q3 2026	Close R-1/R-2/R-3/R-5 remediations; bind cyber-liability insurance; execute audit-firm engagement letter; begin evidence accrual (access reviews, restore tests, monitoring reviews)	Security Officer
Q4 2026	First independent penetration test; SOC 2 Type I examination (Security, Availability, Confidentiality) as of December 2026	Security Officer / Auditor
Q4 2026 – Q2 2027	SOC 2 Type II observation period (≥ 3 months); first design-partner BAAs executed; production environment with PHI subject to full control set from day one	CEO / Security Officer
Q1 2027	HITRUST MyCSF e1 self-assessment complete; external assessor engaged	Security Officer
H1 2027	SOC 2 Type II report issued ; HITRUST e1 validated assessment submitted for certification	Auditor / Assessor
Annually thereafter	Type II re-examination; e1 renewal; risk analysis refresh; policy review cycle	Security Officer

3. ALIGNMENT WITH THE 2025 SECURITY RULE RULEMAKING

ARKA has adopted the principal heightened specifications of the December 2024 OCR proposal as its internal baseline now — mandatory MFA, universal encryption, asset inventory and network mapping, six-month vulnerability scanning, annual penetration testing, segmentation, and seventy-two-hour restoration capability (ARKA-SEC-001, § 5; ARKA-SEC-007). The Company therefore expects no material gap upon finalization of the rule, and tracks the rulemaking docket at each quarterly Committee review.

4. EXTERNAL CLAIMS STANDARD

To preserve credibility in hospital security review and investor diligence, all ARKA personnel and materials shall observe the following claims discipline:

Permitted statements (current)	Prohibited until the referenced artifact exists
“ARKA maintains a HIPAA compliance program aligned	“ARKA is HIPAA certified.” (No such certification

Permitted statements (current)	Prohibited until the referenced artifact exists
to the Privacy, Security, and Breach Notification Rules, with adopted policies and an annual third-party-validated roadmap.”	exists; the phrase signals unsophistication to diligence teams.)
“SOC 2 Type I/Type II in progress; report available under NDA upon issuance.”	“SOC 2 compliant / SOC 2 certified.” (Prohibited until the auditor’s report is issued; then say “SOC 2 Type [I/II] examined, report available under NDA.”)
“HITRUST e1 readiness underway; certification targeted H1 2027.”	“HITRUST certified” or use of the HITRUST seal. (Prohibited until issuance of the validated assessment.)
“Demo environment contains synthetic data only — no PHI.”	Any use of real patient data, however de-identified, to imply live clinical deployment.

5. STANDING DILIGENCE PACKAGE

Upon execution of a non-disclosure agreement, ARKA makes available: this roadmap; the policy index and any requested policies; ARKA-RDY-001 (risk assessment); the BAA template; the Data Security Overview one-pager; and, when issued, auditor and assessor reports. Requests: security@getarka.health.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company’s operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026